SOC2 TYPE II SECURITY COMPLIANCE AUDIT & ASSESSMENT REPORT
Audit Period: January 1, 2025 - September 30, 2025
Auditor: CyberTrust Independent Compliance Partners LLP
Assessment Grade: Certified Compliant (Zero High-Severity Deficiencies)

1. SCOPE OF AUDIT
The audit evaluated the Security, Availability, and Confidentiality Trust Services Criteria for the Intelligent Document Discovery System, covering:
- Node.js / Express backend application servers
- OAuth2 credential lifecycle management for Google Workspace Drive API integrations
- In-memory document parser sandbox handling PDF, DOCX, and text streams
- Storage encryption at rest (AES-256) and in-transit (TLS 1.3)

2. ACCESS CONTROLS & LEAST PRIVILEGE
- Authentication: Multi-factor authentication (MFA) enforced across 100% of internal developer accounts.
- OAuth Tokens: Stored with restricted file permissions, refresh tokens encrypted using KMS keys.
- Directory Crawling Restrictions: Local search workers are restricted from traversing root OS protected folders (/System, /etc, /root, Windows/System32).

3. DATA RETENTION & PARSER ISOLATION
The document parsing engine (pdf-parse and mammoth) executes in stateless memory buffers. Extracted document contents are never retained in persistent disk caches without explicit user indexing consent. Memory buffers are immediately reclaimed following query evaluation.

4. AUDIT FINDINGS & RECOMMENDATIONS
- Recommendation 1: Continue regular dependency audits using npm audit to safeguard against supply chain vulnerabilities.
- Recommendation 2: Maintain strict OAuth scopes (drive.readonly) to prevent unintended modification permissions on user cloud drives.